Actividad 2. Ataque de Diccionario en Plataforma – Explotación de Autenticación débil en DVWA mediante el despliegue de OWASP – ZAP

Maestría en Inteligencia Artificial
Jessica Melani Romero Lora
Dr. Antonio Cedillo Hernández

I. Despliegue de la solución

El presente informe describe las etapas de instalación, experimentación y descripción de un ataque de de diccionario real contra el formulario de autenticación de la página DVWA – Damn Vulnerable Web Application, mediante el uso de OWASP ZAP. Primero, se realiza la intercepción de los datos y posteriormente se ejecuta fuzzing en un entorno de laboratorio aislado.



2. Aislamiento con Docker

Se levantó DVWA para ejecutar la base de datos MariaDB, a partir de este entorno se preparó:

- OWASP ZAP (Zed Attack Proxy) – Proxy de Interceptación y del motor de arranque de fuzzy sobre las contraseñas.
- DVWA – entorno de la aplicación web – objetivo.
- Docker para poder desplegar tanto DVWA como su database.

3. Desarrollo de la práctica

Durante la primera parte de la interceptación de la petición de login, se configuró el explorador en modo proxy mediante ZAP, posteriormente se accedió al formulario de DVWA para interceptar la petición POST enviada a login.php. En este momento, se busca identificar el punto fuzzing (SFUZZ) dejándolo como el parámetro central para la ejecución del ataque.

Despliegue del entorno Docker:

```
$ docker-compose up -d
[+] Running 3/3
 ✔ Volume "lab_dvwa_db"   Created
 ✔ Container dvwa-db      Started
 ✔ Container dvwa         Started
```

Se creó un diccionario con diez contraseñas, incluyendo la contraseña correcta –password– en la posición 6. Se marcó el campo, seleccionando la función fuzzy, cargando el diccionario como payload de tipo archivo. Posteriormente, se activó la función fuzz cargando el diccionario y activamos – seguir redirecciones –, paso indispensable para diferenciar el acierto con respecto a la respuesta correcta. Mediante peticiones HTTP fue posible reproducir el ataque y automatizar el comportamiento. De esta manera se registró para cada credencial el estado HTTP. Se realizó una redirección del estado de HTTP y el tamaño de la respuesta esperada.

Despliegue del diccionario

```
$ cat diccionario.txt
123456
admin
letmein
qwerty
dragon
password
football
monkey
abc123
iloveyou
```

#	Contraseña	Estado	Redirección	Tamaño	Resultado
1	123456	302	login.php	1342 B	Fallido
2	admin	302	login.php	1342 B	Fallido
3	letmein	302	login.php	1342 B	Fallido
4	qwerty	302	login.php	1342 B	Fallido
5	dragon	302	login.php	1342 B	Fallido
6	**password**	**302**	**index.php**	**6443 B**	**Éxito**
7	football	302	login.php	1342 B	Fallido
8	monkey	302	login.php	1342 B	Fallido
9	abc123	302	login.php	1342 B	Fallido
10	iloveyou	302	login.php	1342 B	Fallido

Tabla 1. Resultados reales del ataque de diccionario (admin:<payload>). La credencial admin:password se distingue por su redirección a index.php y su tamaño de respuesta de 6443 B, frente a los 1342 B y la redirección a login.php de los nueve intentos fallidos. Elaboración propia.

Como podemos observar, solo password – intento 6 fue capaz de redirigir el index.php, devolviendo 6443 bytes en comparación con los 1342 bytes, mientras que las demás opciones obtuvieron constantes números fallidos. Como se puede apreciar en la tabla, una credencial incorrecta recarga login.php, enviando constantes requests a las bases de datos de DVWA. Por otra parte, una opción correcta arroja el mensaje admin:password de manera directa posterior al proceso de autenticación de DVWA.

Ejecución del ataque de diccionario sobre el campo Password

```
$ zap-cli fuzz --url http://localhost:8080/login.php \
  --field password --payload diccionario.txt --follow-redirects

[#1]  123456     -> 302 -> login.php  -> 1342 B -> FALLIDO
[#2]  admin      -> 302 -> login.php  -> 1342 B -> FALLIDO
[#3]  letmein    -> 302 -> login.php  -> 1342 B -> FALLIDO
[#4]  qwerty     -> 302 -> login.php  -> 1342 B -> FALLIDO
[#5]  dragon     -> 302 -> login.php  -> 1342 B -> FALLIDO
[#6]  password   -> 302 -> index.php -> 6443 B -> EXITO
[#7]  football   -> 302 -> login.php  -> 1342 B -> FALLIDO
[#8]  monkey     -> 302 -> login.php  -> 1342 B -> FALLIDO
[#9]  abc123     -> 302 -> login.php  -> 1342 B -> FALLIDO
[#10] iloveyou   -> 302 -> login.php  -> 1342 B -> FALLIDO

[*] Ataque finalizado: 10 intentos, 1 credencial válida
encontrada.
[*] Credencial: admin:password
```

Preguntas de la práctica

1. **¿Qué soluciones propone para mitigar el riesgo de este tipo de ataques en un sitio propio?**
   Propongo una defensa in depth con contraseñas robustas con caracteres, números y símbolos combinatorios, así como rechazo de términos provenientes de diccionarios y contraseñas filtradas. También es pertinente restringir el número de intentos para acceder a una cuenta por usuario e IP. Vale la pena configurar una autenticación multifactor (TOTP – FIDO02 y notificaciones push). De manera complementaria, una autenticación con CAPTCHA permite detener los ataques automatizados en plataformas y sitios vulnerables a ataques con mayor complejidad.

2. **¿Qué puedes concluir de lo aprendido con este tipo de ataques?**
   Durante esta práctica pude observar lo sencillo que es vulnerar un website con una contraseña débil, la centralidad de una contraseña con mayor complejidad para vulnerarla y la naturaleza de los diccionarios que comprometen la seguridad de las cuentas personales de los usuarios y de su información. Me llamó mucho la atención que estos ataques pueden ser automatizados de manera sencilla también, si bien en esta práctica configuramos paso a paso el proxy y el fuzzy, creo que debe haber múltiples maneras de optimizar la velocidad y agresividad del ataque.